

Лекция 7. Политики и модели разграничения доступа в компьютерных системах

Учебные вопросы:

1. Политика и модели безопасности в компьютерных системах
2. Субъектно – объектные модели разграничения доступа
3. Политика и модели дискреционного доступа
4. Политика и модели мандатного доступа
5. Политика и модели тематического разграничения доступа
6. Политика ролевой модели разграничения доступа

1. Политика и модели безопасности в компьютерных системах

Под *политикой безопасности* понимается совокупность норм и правил, регламентирующих процесс обработки информации, выполнение которых обеспечивает защиту от определенного множества угроз и составляет необходимое условие безопасности системы. Формальное выражение политики безопасности называют *моделью безопасности*.

Основная цель создания политики безопасности — это определение условий, которым должно подчиняться поведение системы, выработка критерия безопасности и проведение формального доказательства соответствия системы этому критерию при соблюдении установленных правил и ограничений.

Модели безопасности обеспечивают системотехнический подход, включающий решение следующих задач:

~ выбор и обоснование базовых принципов архитектуры



защищенных систем, определяющих механизмы реализации средств и методов защиты информации;

- ~ подтверждение свойства защищенности разрабатываемых систем путем формального доказательства соблюдения политики безопасности;

- ~ составление формальной спецификации политики безопасности как важнейшей составной части организационного и документационного обеспечения разрабатываемых защищенных систем.

Производители защищенных информационных систем используют модели безопасности в следующих случаях:

- ~ при составлении формальной спецификации политики безопасности разрабатываемой системы;

- ~ при выборе и обосновании базовых принципов архитектуры защищенной системы, определяющих механизмы реализации средств защиты;

- ~ в процессе анализа безопасности системы, при этом модель используется в качестве эталонной модели;

- ~ при подтверждении свойств разрабатываемой системы путем формального доказательства соблюдения политики безопасности.

Потребители путем составления формальных моделей безопасности получают возможность довести до сведения производителей свои требования, а также оценить соответствие защищенных систем своим потребностям.

Эксперты в ходе анализа адекватности реализации политики безопасности в защищенных системах используют модели безопасности в качестве эталонов.

По сути, модели безопасности являются связующим элементом между производителями, потребителями и экспертами.

2. Субъектно – объектные модели разграничения доступа

Разграничение доступа к информации — разделение информации, циркулирующей в информационной системе, на части, элементы, компоненты, объекты и т. д. и организация системы работы с информацией, предполагающей доступ пользователей к той части (к тем компонентам) информации, которая им необходима для выполнения функциональных обязанностей.



Разграничение доступа непосредственно обеспечивает конфиденциальность информации, а также снижает вероятность реализации угроз целостности и доступности. Разграничение доступа можно рассматривать среди других методов обеспечения информационной безопасности как комплексный

программно-технический метод защиты информации. Разграничение доступа является также необходимым условием обеспечения информационной безопасности.

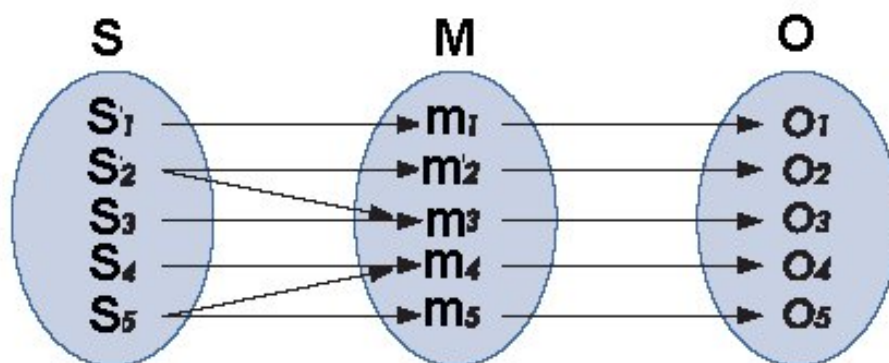
Большинство моделей разграничения доступа основывается на представлении системы как совокупности субъектов и объектов доступа.

Рассмотрим основные положения наиболее распространенных политик безопасности, основанных на контроле доступа субъектов к объектам и моделирующих поведение системы с помощью пространства состояний, одни из которых являются безопасными, а другие — нет. Все рассматриваемые модели безопасности основаны на следующих базовых представлениях:

1. В системе действует дискретное время.

2. В каждый фиксированный момент времени система представляет собой конечное множество элементов, разделяемых на два подмножества (Рисунок 1):

- ~ подмножество субъектов доступа S ;
- ~ подмножество объектов доступа O .



Модель защиты информации по действующей концепции:
S – множество субъектов (угроз); **M** – множество защитных функций;
O – множество объектов защиты

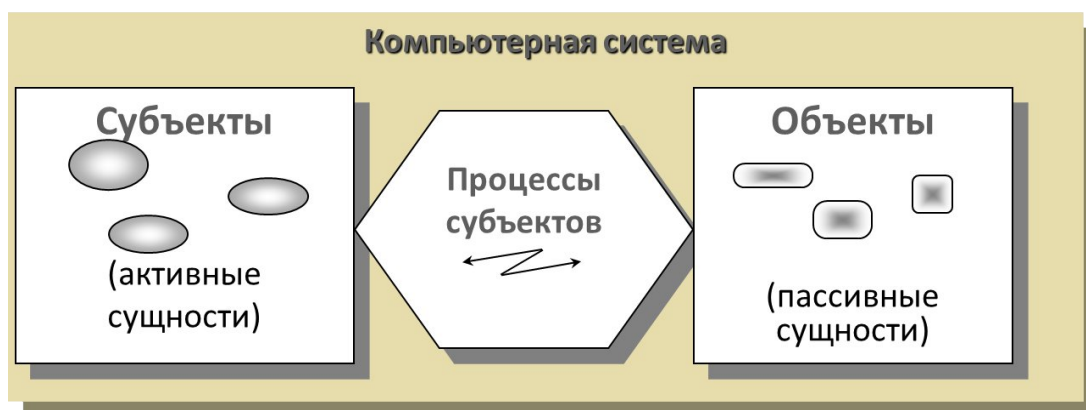


Рис.1 Модель защиты информации

3. Пользователи КС представлены одним или некоторой совокупностью субъектов доступа, действующих от имени конкретного пользователя.

4. Субъекты КС могут быть порождены из объектов только активной сущностью (другим субъектом).

5. Все взаимодействия в системе моделируются установлением отношений определенного типа между субъектами и

объектами. Множество типов отношений определяется в виде набора операций, которые субъекты могут производить над объектами.

6. Все процессы безопасности в КС описываются доступами субъектов к объектам, вызывающими потоки информации.

7. Политика безопасности задается в виде правил, в соответствии с которыми должны осуществляться все взаимодействия между субъектами и объектами. Взаимодействия, приводящие к нарушению этих правил, пресекаются средствами контроля доступа и не могут быть осуществлены.

8. Все операции контролируются монитором безопасности и либо запрещаются, либо разрешаются в соответствии с правилами политики безопасности.

9. Совокупность множеств субъектов, объектов и отношений между ними (установившихся взаимодействий) определяет *состояние* системы. Каждое состояние системы является либо *безопасным*, либо *небезопасным* в соответствии с предложенным в модели критерием безопасности.

10. Основной элемент модели безопасности — это доказательство утверждения (теоремы) о том, что система, находящаяся в безопасном состоянии, не может перейти в небезопасное состояние при соблюдении всех установленных правил и ограничений.

Под **субъектом** доступа понимается активная сущность КС, которая может изменять состояние системы через порождение процессов над объектами, в том числе, порождать новые объекты и инициализировать порождение новых субъектов.

Под **объектом** доступа понимается пассивная сущность КС, процессы над которой могут в определенных случаях быть источником порождения новых субъектов.

Под **пользователем** КС понимается лицо, внешний фактор, аутентифицируемый некоторой информацией, и управляющий одним или несколькими субъектами, воспринимающий объекты и получающий информацию о состоянии КС через субъекты, которыми он управляет.

Понятия субъектов доступа и пользователей не тождественны.

Утверждение 1: В защищенной информационной системе в любой момент времени любой субъект и объект должны быть идентифицированы и аутентифицированы.

Утверждение 2. В защищенной системе должна присутствовать активная компонента (субъект, процесс и т. д.) с соответствующим объектом-источником, которая осуществляет управление доступом и контроль доступа субъектов к объектам, — монитор или ядро безопасности.

Монитор безопасности — механизм реализации политики безопасности в информационной системе, совокупность аппаратных, программных и специальных компонентов системы, реализующих функции защиты и обеспечения безопасности (Рисунок 2).

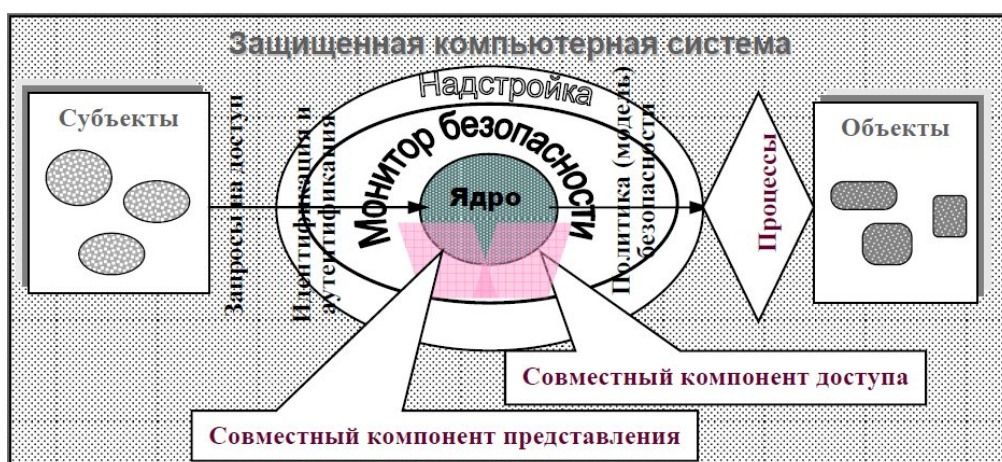


Рис. 2 – Монитор безопасности.

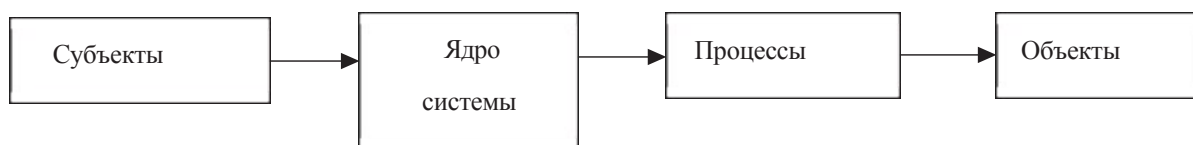


Рис. 3 – Незащищенная система

В защищенной системе появляется дополнительный компонент, обеспечивающий процессы защиты информации, прежде всего процедуры идентификации/аутентификации, а также управление доступом на основе той или иной политики безопасности (разграничения доступа) (Рисунок 4).

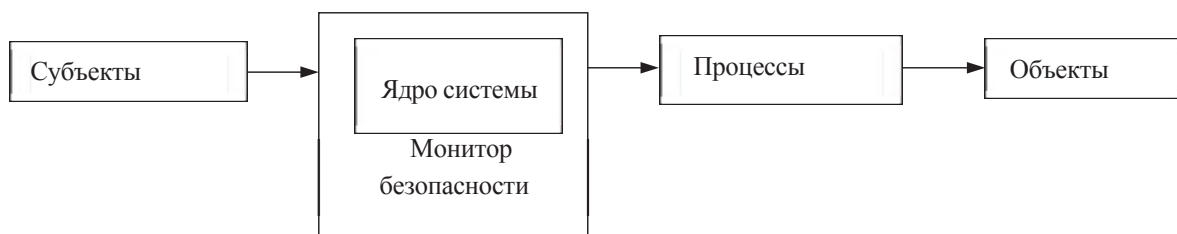


Рис.4 – Защищенная система

Монитор безопасности в защищенной системе является субъектом осуществления принятой политики безопасности, реализуя через алгоритмы своей работы соответствующие модели безопасности.

Утверждение 3. Для реализации принятой политики безопасности, управления и контроля доступа субъектов к объектам необходима информация и объект, ее содержащий.

К настоящему времени разработано большое количество различных моделей безопасности, все они выражают несколько исходных политик безопасности. При этом имеет значение критерий безопасности доступов субъектов к объектам, т. е. правило разделения информационных потоков, порождаемых доступом субъектов к объектам, на безопасные и небезопасные. Система безопасна тогда и только тогда, когда субъекты не имеют возможностей нарушать (обходить) установленную в системе политику безопасности.

Субъектом обеспечения политики безопасности выступает монитор безопасности. Его наличие в структуре системы соответственно является *необходимым* условием безопасности. Что касается условий *достаточности*, то они заключены в безопасности самого монитора безопасности.

3. Политика и модели дискреционного доступа

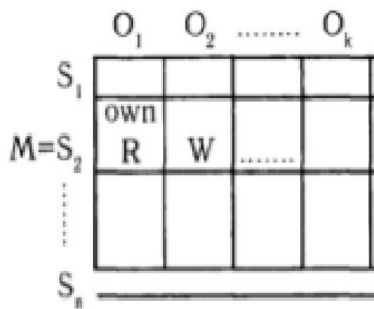
Политика дискреционного (избирательного) доступа реализована в большинстве защищенных систем и исторически является первой проработанной в теоретическом и практическом плане. Первые описания моделей дискреционного доступа к информации появились еще в 1960-х гг. и подробно представлены в литературе. Наиболее известны модель АДЕПТ-50 (конец 1960-х гг.), пятимерное пространство Хартсона (начало 1970-х гг.), модель Хариссона — Руззо-Ульмана (середина 1970-х гг.), модель Take-Grant (1976 г.). Авторами и исследователями этих моделей был внесен значительный вклад в теорию безопасности информационных систем, а их работы заложили основу для последующего создания и развития защищенных информационных систем.



Модели дискреционного доступа непосредственно основываются на субъектно-объектной модели и развивают ее как совокупность некоторых множеств взаимодействующих элементов (субъектов, объектов и т. д.). Множество (область) безопасных доступов в моделях дискреционного доступа определяется дискретным набором троек «пользователь (субъект) — поток (операция) — объект».

На практике наибольшее применение получили дискреционные модели, основанные на матрице доступа. В данных моделях область

безопасного доступа строится как прямоугольная матрица (таблица), строки которой соответствуют субъектам доступа, столбцы — объектам доступа, а в ячейках записываются разрешенные операции (права) субъекта над объектом. В матрице используются следующие обозначения: *w* — «писать», *r* — «читать», *e* — «исполнять» (Рисунок 5).



объекты субъекты											
	file1	file2	dir1	file3	docA	docB	docC	docD	dir2	file4	pic1
adm	rwx	rwx	rwx	rwx	rwx	rwx	rwx	rwx	rwx	rwx	rwx
pgm1	---	---	---	r-x	---	---	---	---	rwx	rwx	---
pgm2	rwx	rwx	rwx	r-x	---	---	---	---	rwx	rwx	---
pgm3	rwx	rwx	rwx	---	---	---	---	---	---	---	---
op1	---	---	rwx	r-x	---	---	---	---	---	---	---
op2	---	---	rwx	r-x	---	---	---	---	---	---	---
op3	---	---	rwx	r-x	---	---	---	---	---	---	---
us1	--x	---	r--	---	rwx	rwx	---	r--	---	---	---
us2	---	---	r--	---	r--	r--	---	r--	---	---	---
us3	--x	---	r--	---	r--	r--	rwx	rwx	---	---	rwx

Рис.5 – Модели на основе матрицы доступа

Дискреционное разграничение доступа

	O ₁ 	O ₂ 	O ₃ 
S ₁ 	R W X	R X	R W X
S ₂ 	R X	R W	W X
S ₃ 	R	X	W

4

Рис. 6 – Дискреционное разграничение доступа

Матрица доступа представляет собой ассоциированный с монитором безопасности объект, содержащий информацию о политике разграничения доступа в конкретной системе. Структура матрицы, ее создание и изменение определяются конкретными моделями и конкретными программно-техническими решениями систем, в которых они реализуются.

Принцип организации матрицы доступа в реальных системах определяет использование двух подходов — централизованного и распределенного.

При *централизованном* подходе матрица доступа создается как отдельный самостоятельный объект с особым порядком размещения и доступа к нему. Количество объектов и субъектов доступа в реальных системах может быть велико. Для уменьшения количества столбцов матрицы объекты доступа могут делиться на две группы — группу объектов, доступ к которым не ограничен, и группу объектов дискреционного доступа. В матрице доступа представляются права

пользователей только к объектам второй группы. Наиболее известным примером такого подхода являются «биты доступа» в UNIX-системах.

При *распределенном* подходе матрица доступа как отдельный объект не создается, а представляется или «*списками доступа*», распределенными по объектам системы, или «*списками возможностей*», распределенными по субъектам доступа. В первом случае каждый объект системы, помимо идентифицирующих характеристик, наделяется еще своеобразным списком, непосредственно связанным с самим объектом и представляющим, по сути, соответствующий столбец матрицы доступа. Во втором случае список с перечнем разрешенных для доступа объектов (строку матрицы доступа) получает каждый субъект при своей инициализации.

Согласно *принципу управления доступом* выделяются два подхода:

- ~ принудительное управление доступом;
- ~ добровольное управление доступом.

В случае принудительного управления право создания и изменения матрицы доступа имеют только субъекты администратора системы, который при регистрации для работы в системе нового пользователя создает с соответствующим заполнением новую строку матрицы доступа, а при возникновении нового объекта, подлежащего избирательному доступу, образует новый столбец матрицы доступа. Подобный подход наиболее широко представлен в базах данных.

Принцип *добровольного управления доступом* основывается на принципе владения объектами. Владельцем объекта доступа называется пользователь, инициализировавший поток, в результате чего объект возник в системе, или определивший его иным образом. Права доступа к объекту определяют их владельцы.

Заполнение и изменение ячеек матрицы доступа осуществляют субъекты пользователей-владельцев соответствующих объектов.

Подобный подход обеспечивает управление доступом в тех системах, в которых количество объектов доступа является значительным или неопределенным. Такая ситуация типична для операционных систем.

Все дискреционные модели уязвимы для атак с помощью «троянских» программ, поскольку в них контролируются только операции доступа субъектов к объектам, а не потоки информации между ними. Поэтому, когда «троянская» программа переносит информацию из доступного этому пользователю объекта в объект, доступный нарушителю, то формально никакое правило дискреционной политики безопасности не нарушается, но утечка информации происходит.

4. Политика и модели мандатного доступа

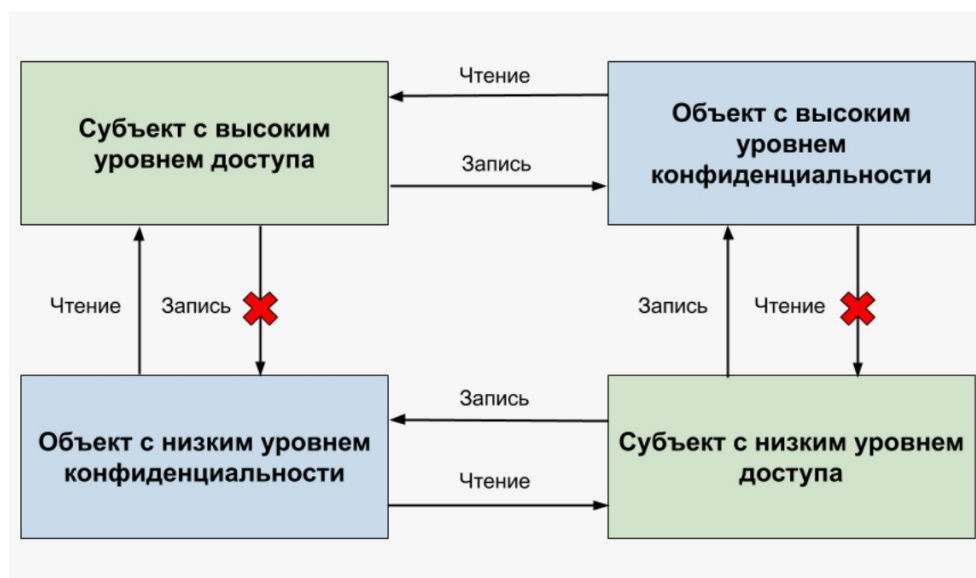
Политика мандатного доступа является примером использования технологий, наработанных во в некомпьютерной сфере, в частности принципов организации секретного делопроизводства и документооборота, применяемых в государственных структурах большинства стран.

Основным положением политики мандатного доступа является назначение всем участникам процесса обработки защищаемой информации и документам, в которых она содержится, специальной метки, например *секретно*, *сов. секретно* и т. д., получившей название уровня безопасности. Все уровни безопасности упорядочиваются с помощью установленного отношения доминирования, например, уровень *сов. секретно* считается более высоким, чем уровень *секретно*. Контроль доступа осуществляется в зависимости от уровней безопасности взаимодействующих сторон на основании двух правил:

1. *No read up (NRU)* — нет чтения вверх: субъект имеет право читать только те документы, уровень безопасности которых не превышает его собственный уровень безопасности.

2. *No write down (NWD)* — нет записи вниз: субъект имеет право заносить информацию только в те документы, уровень безопасности которых не ниже его собственного уровня безопасности.

Первое правило обеспечивает защиту информации, обрабатываемой более доверенными (высокоуровневыми) лицами, от доступа со стороны менее доверенных (низкоуровневых). Второе правило предотвращает утечку информации (сознательную или неосознанную) от высокоуровневых участников процесса обработки информации к низкоуровневым.



Мандатное модель доступа

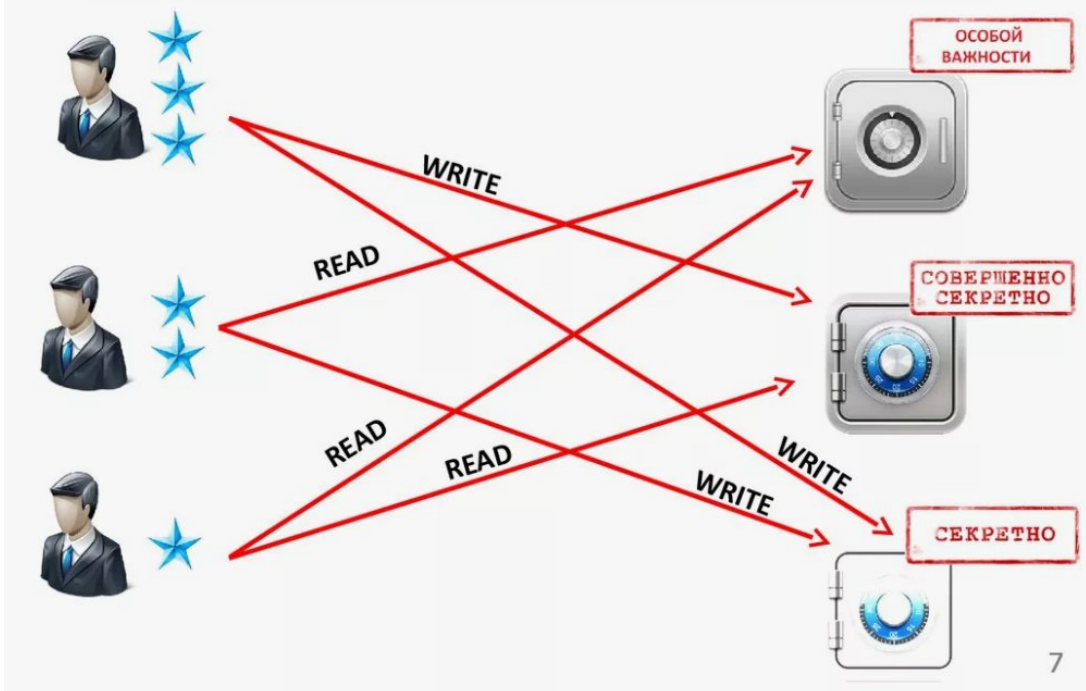


Рис.7 Мандатное разграничение доступа

Таким образом, если в дискреционных моделях управление доступом происходит путем наделения пользователей полномочиями осуществлять определенные операции над определенными объектами, то мандатные модели управляют доступом неявным образом — с помощью назначения всем сущностям системы уровней безопасности, которые определяют все допустимые взаимодействия между ними. Следовательно, мандатное управление доступом не различает сущностей, которым присвоен одинаковый уровень безопасности, и на их взаимодействия ограничения отсутствуют. Любой объект определенного уровня безопасности доступен любому субъекту соответствующего уровня безопасности (с учетом правил NRU и NWD). Мандатный подход к разграничению доступа, основанный лишь на понятии уровня безопасности, без учета специфики других характеристик субъектов и объектов приводит в большинстве случаев к избыточности прав доступа конкретных субъектов в пределах соответствующих классов безопасности. Для устранения данного

недостатка мандатный принцип разграничения доступа дополняется дискреционным внутри соответствующих классов безопасности. В теоретических моделях для этого вводят *матрицу доступа*, разграничивающую разрешенный по мандатному принципу доступ к объектам одного уровня безопасности.

5. Политика и модели тематического разграничения доступа

Политика тематического разграничения доступа близка к политике мандатного доступа.

Общей основой является введение специальной процедуры классификации сущностей системы (субъектов и объектов доступа) по какому-либо критерию.

В ряде случаев основанием для классификации информации и субъектов доступа к ней выступают не конфиденциальность данных и доверие к субъектам доступа, как в мандатных моделях, а тематическая структура предметной области информационной системы. Стремление расширить мандатную модель для отражения тематического принципа разграничения доступа, применяемого в государственных организациях многих стран, привело к использованию более сложных структур, чем линейная решетка уровней безопасности, именуемых MLS- решетками. MLS-решетка является произведением линейной решетки уровней безопасности и решетки подмножеств множества категорий (тематик).

Еще одним фактором, обуславливающим необходимость построения специальных моделей тематического разграничения доступа, является то, что в большинстве случаев на классификационном множестве в документальных информационных системах устанавливается не линейный порядок (как на множестве уровней безопасности в мандатных моделях), а частичный порядок, задаваемый определенного вида корневыми деревьями

(иерархические и фасетные рубрикаторы).

Важным аспектом, присутствующим в практике разграничения доступа к «бумажным» ресурсам, является тематическая «окрашенность» информационных ресурсов предприятий, учреждений по организационно-технологическим процессам и профилям деятельности. Организация доступа сотрудников к информационным ресурсам (в библиотеках, архивах, документальных хранилищах) осуществляется на основе *тематических классификаторов*. Все документы информационного хранилища тематически индексируются, т. е. соотносятся с теми или иными тематическими рубриками классификатора. Сотрудники предприятия согласно своим функциональным обязанностям или по другим основаниям получают права работы с документами определенной тематики. Данный подход в сочетании с дискреционным и мандатным доступом, обеспечивает более адекватную и гибкую настройку системы разграничения доступа на конкретные функционально-технологические процессы, предоставляет дополнительные средства контроля и управления доступом.

6. Политика ролевой модели разграничения доступа

Ролевая модель безопасности представляет собой существенно усовершенствованную модель Харрисона–Руззо–Ульмана, однако ее нельзя отнести ни к дискреционным, ни к мандатным, потому что управление доступом в ней осуществляется как на основе матрицы прав доступа для ролей, так и с помощью правил, регламентирующих назначение ролей пользователям и их активацию во время сеансов. Поэтому ролевая модель представляет собой совершенно особый тип политики, которая основана на компромиссе между гибкостью управления доступом, характерной для дискреционных моделей, и жесткостью правил контроля доступа, присущей мандатным моделям.

В ролевой модели классическое понятие «субъект» замещается понятиями «пользователь» и «роль». **Пользователь** — это человек, работающий с системой и выполняющий определенные служебные обязанности. Роль — это активно действующая в системе абстрактная сущность, с которой связан набор полномочий, необходимых для осуществления определенной деятельности. Самым распространенным примером роли является присутствующий почти в каждой системе административный бюджет (например, root для UNIX и Administrator для Windows NT), который обладает специальными полномочиями и может использоваться несколькими пользователями.

Ролевая политика распространена очень широко, потому что она, в отличие от других более строгих и формальных политик, очень близка к реальной жизни. Ведь на самом деле работающие в системе пользователи действуют не от своего личного имени, они всегда осуществляют определенные служебные обязанности, т. е. выполняют некоторые роли, которые никак не связаны с их личностью.

Поэтому вполне логично осуществлять управление доступом и назначать полномочия не реальным пользователям, а абстрактным (неперсонифицированным) ролям, представляющим участников определенного процесса обработки информации. Такой подход к политике безопасности позволяет учесть разделение обязанностей и полномочий между участниками прикладного информационного процесса, т. к. с точки зрения ролевой политики имеет значение не личность пользователя, осуществляющего доступ к информации, а то, какие полномочия ему необходимы для выполнения его служебных обязанностей.

В такой ситуации ролевая политика позволяет распределить полномочия между этими ролями в соответствии с их служебными обязанностями: роли администратора назначаются специальные полномочия, позволяющие ему контролировать работу системы и

управлять ее конфигурацией, роль менеджера баз данных позволяет осуществлять управление сервером баз данных, а права простых пользователей ограничиваются минимумом, необходимым для запуска прикладных программ. Кроме того, количество ролей в системе может не соответствовать количеству реальных пользователей: один пользователь, если на нем лежит множество обязанностей, требующих различных полномочий, может выполнять (одновременно или последовательно) несколько ролей, а несколько пользователей могут выполнять одну и ту же роль, если они производят одинаковую работу.

При использовании ролевой политики управление доступом осуществляется в две стадии: во-первых, для каждой роли указывается набор полномочий, представляющий набор прав доступа к объектам, во-вторых — каждому пользователю назначается список доступных ему ролей. Полномочия назначаются ролям в соответствии с принципом наименьших привилегий, из которого следует, что каждый пользователь должен обладать только минимально необходимым для выполнения своей работы набором полномочий.

Basic RBAC Illustrated

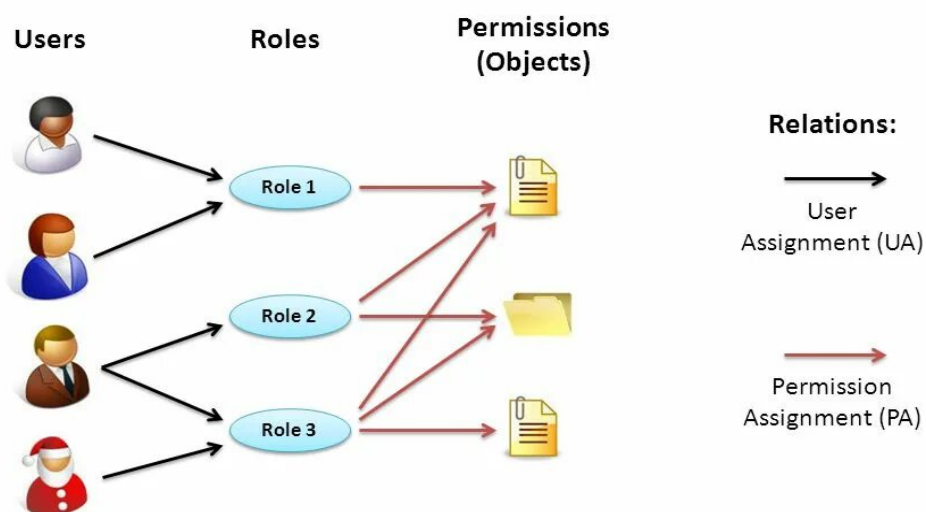


Рис. 8 Ролевая политика разграничения доступа

В отличие от других политик, ролевая политика практически не гарантирует безопасность с помощью формального доказательства, а только определяет характер ограничений, соблюдение которых и служит критерием безопасности системы. Такой подход позволяет получать простые и понятные правила контроля доступа, которые легко могут быть применены на практике, но лишает систему теоретической доказательной базы. В некоторых ситуациях это обстоятельство затрудняет использование ролевой политики, однако в любом случае оперировать ролями гораздо удобнее, чем субъектами, поскольку это более соответствует распространенным технологиям обработки информации, предусматривающим разделение обязанностей и сфер ответственности между пользователями. Кроме того, ролевая политика может использоваться одновременно с другими политиками безопасности, когда полномочия ролей, назначаемых пользователям, контролируются дискреционной или мандатной политикой, что позволяет строить многоуровневые схемы контроля доступа.